

**Министерство образования Республики Беларусь
Учреждение образования
«Белорусский государственный университет
информатики и радиоэлектроники»**

**Факультет информационных технологий и управления
Кафедра интеллектуальных информационных технологий**

**ОТЧЁТ
по лабораторной работе № 2 (часть 2)
по дисциплине
«Проектирование защищенных интеллектуальных
информационных систем»**

Тема: Оценка защищённости сторонней системы VulnNotes

Выполнил:
студент группы 321701
Струнец Д. П.

Проверил:
Сальников Д. А.

Минск 2026

1 ПОСТАНОВКА ЗАДАЧИ

Целью лабораторной работы является разработка методики оценки защищённости сторонних программных систем и применение этой методики к предоставленному приложению (результат лабораторной работы № 2, часть 1 — веб-приложение VulnNotes). Необходимо выполнить анализ по политике безопасности ОС, компонентов и их взаимодействия, сетевой политике и конфиденциальности данных; предложить меры усовершенствования и рекомендации по безопасному использованию.

2 КРАТКОЕ ОПИСАНИЕ ПРЕДОСТАВЛЕННОЙ СИСТЕМЫ

VulnNotes — учебно-демонстрационное веб-приложение на Flask + SQLite, развёрнутое в контейнере Docker (Ubuntu 22.04), UI: <http://localhost:5050>. Функции: регистрация/авторизация/logout, CRUD публичных и конфиденциальных заметок, поиск. Процесс выполняется от пользователя appuser. В приложении намеренно присутствуют уязвимости OWASP Top 10:2025 для целей обучения и анализа.

[Home](#) [Public notes](#) [Confidential](#) [Search](#) [OWASP map](#) Hi, alice (user) [Logout](#)

Вход выполнен

VulnNotes

Учебное приложение с OWASP Top 10 уязвимостями. Не для production.

- Регистрация / логин / logout
- CRUD публичных заметок
- CRUD конфиденциальных заметок
- Поиск

Сид: admin/admin, alice/alice, bob/bob123, guest/guest

Рисунок 1 – Главная страница VulnNotes после авторизации

OWASP Top 10:2025 — карта уязвимостей

owasp.org/Top10/2025

ID	Категория	Где в приложении
A01	Broken Access Control	IDOR /confidential/<id>, /api/notes; SSRF /fetch
A02	Security Misconfiguration	DEBUG=True, /debug/config, hardcode secret
A03	Software Supply Chain Failures	старые deps без hashes (requirements.txt)
A04	Cryptographic Failures	plaintext passwords, нет TLS
A05	Injection	SQLi /login и /search; XSS /search?q=
A06	Insecure Design	нет rate limit / MFA / политики паролей
A07	Authentication Failures	слабые пароли, cookie без HttpOnly
A08	Software or Data Integrity Failures	/import pickle.loads
A09	Security Logging and Alerting Failures	failed login не пишется
A10	Mishandling of Exceptional Conditions	SQL/exception text в ответе /search

[SSRF \(A01\)](#) · [Pickle \(A08\)](#) · [Debug \(A02\)](#) · [Bad SQL \(A10\)](#)

Рисунок 2 – Встроенная карта уязвимостей OWASP Top 10:2025

3 РАЗРАБОТАННАЯ МЕТОДИКА ОЦЕНКИ ЗАЩИЩЁННОСТИ

Методика представляет собой многоуровневый чек-лист с фиксацией находок, уровня риска (критический / высокий / средний / низкий) и доказательств (скриншот, HTTP-запрос, лог). Этапы:

- Инвентаризация: границы системы, роли, данные (публичные / конфиденциальные), порты, зависимости.
- Анализ ОС и окружения: пользователь процесса, SUID/sudo, секреты на диске, изоляция контейнера.
- Анализ компонентов: веб-фреймворк, СУБД, библиотеки (версии, известные CVE), сериализация, debug-режимы.
- Анализ взаимодействия: аутентификация, авторизация (IDOR), API, SSRF, cookie-флаги, каналы HTTP/TLS.
- Анализ конфиденциальности: хранение паролей/ПД, шифрование at-rest, утечки в ошибках и логах.
- Динамическая проверка (black-box): SQLi, XSS, brute force, доступ к чужим ресурсам, сканеры по необходимости.

- Организационный уровень: политики паролей, аудит, реагирование на инциденты.
- Документирование: сводная таблица находок → рекомендации по устранению и безопасной эксплуатации.

Критерий приемлемости: отсутствие критических и высоких дефектов в контуре аутентификации, авторизации и хранения секретов; наличие журналирования security-событий; TLS и безопасные cookie в production.

4 АНАЛИЗ ЗАЩИЩЁННОСТИ ПО РАЗРАБОТАННОЙ МЕТОДИКЕ

4.1 Политика безопасности операционной системы

Положительно: процесс Flask не от root (appuser). Отрицательно: в образе оставлены учебные векторы повышения привилегий (SUID backup-tool, sudo find NOPASSWD), на диске доступны подсказки пароля (/opt/backup/.root_hint, ~/.env). Риск: компрометация веб-приложения легко переходит в root внутри контейнера.

4.2 Компоненты и их взаимодействие

Выявлены: SQL-инъекция в /login и /search; XSS на /search; IDOR /confidential/<id>; неавторизованный API /api/notes/<id>; pickle deserialization на /import; SSRF /fetch; DEBUG=True и /debug/config с утечкой secret_key; пароли в plaintext; SESSION_COOKIE_HTTPONLY=False; отсутствие rate limit и security-логов.

Вход выполнен

VulnNotes

Учебное приложение с OWASP Top 10 уязвимостями. Не для production.

- Регистрация / логин / logout
- CRUD публичных заметок
- CRUD конфиденциальных заметок
- Поиск

Сид: admin/admin, alice/alice, bob/bob123, guest/guest

Рисунок 3 – Обход аутентификации SQL-инъекцией

Confidential #1

owner_id=1

Admin secret

ssn: 123-45-6789; card: 4111111111111111

Рисунок 4 – IDOR: доступ к чужой конфиденциальной заметке

SQL error: near "style": syntax error

```
SELECT id, title, body, 'public' AS kind FROM public_notes WHERE title LIKE '%
```

```
Stolen cookies:
session=eyJyY2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wClwEgEHYFYtyodGtBtX5tM
```

```
%' OR body LIKE '%
```

```
Stolen cookies:
session=eyJyY2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wClwEgEHYFYtyodGtBtX5tM
```

```
%' UNION ALL SELECT id, title, body, 'confidential' AS kind FROM confidential_notes WHERE title LIKE '%
```

```
Stolen cookies:
session=eyJyY2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wClwEgEHYFYtyodGtBtX5tM
```

```
%' OR body LIKE '%
```

```
Stolen cookies:
session=eyJyY2x1IjoidXNlciIsInVzZXJfaWQiOjJ9.apgBkQ.-Dt9wClwEgEHYFYtyodGtBtX5tM
```

```
%'
```

Рисунок 5 – XSS: кража session cookie через document.cookie

```
Pretty-print
{
  "db_path": "/app/data/app.db",
  "debug": true,
  "secret_key": "super-secret-hardcoded-key-12345",
  "users_list": ["admin/admin", "alice/alice"]
}
```

Рисунок 6 – Утечка конфигурации через /debug/config

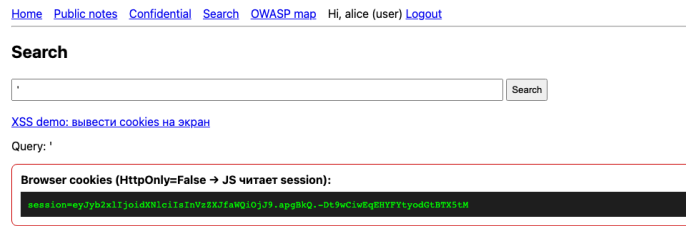


Рисунок 7 – Утечка SQL и текста исключения клиенту

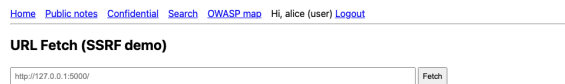


Рисунок 8 – SSRF: сервер выполняет произвольный HTTP-запрос

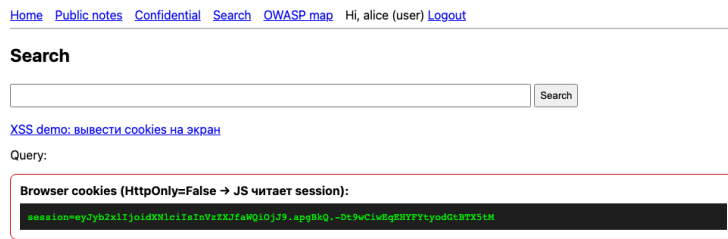


Рисунок 9 – Cookie сессии доступна JavaScript (нет HttpOnly)

4.3 Сетевая политика безопасности

Сервис слушает 0.0.0.0 внутри контейнера, публикация на хост :5050. Трафик без TLS; cookie без Secure. SSRF позволяет обращаться к внутренним адресам (127.0.0.1). Сетевых ACL/WAF нет.

4.4 Конфиденциальность данных

Конфиденциальные заметки и пароли хранятся открытым текстом в SQLite. Разграничение на уровне списка обходится IDOR и открытым API. XSS + отсутствие HttpOnly приводит к угону сессии. Итог: конфиденциальность не обеспечивается.

4.5 Сводная оценка

По методике система оценивается как не готовая к эксплуатации: множество критических дефектов (A01, A04, A05, A07, A08 по OWASP Top 10:2025). Приложение пригодно только как учебный стенд.

5 КОМПЛЕКС МЕР ПО УСОВЕРШЕНСТВОВАНИЮ

- Параметризованные SQL-запросы; экранирование/шаблоны без `|safe` для пользовательского ввода.
- Проверка владельца на каждой операции с `confidential`; аутентификация API; запрет IDOR.

- Хэширование паролей (argon2/bcrypt); TLS; cookie: HttpOnly, Secure, SameSite=Lax/Strict.
- Отключить DEBUG; удалить /debug/config; единый error handler без утечки стека/SQL.
- Запретить pickle от клиента (JSON); allowlist URL для исходящих запросов (анти-SSRF).
- Rate limit / lockout на /login; MFA для admin; политика сложности паролей.
- Журналирование failed login, IDOR, admin-действий; алерты.
- Шифрование at-rest для confidential_notes; ротация secret_key.
- Убрать учебные SUID/sudo; secrets только через env/secret store; non-root + read-only FS.
- Зафиксировать зависимости (lock + hashes), SBOM, регулярный audit/CVE-scan.

6 РЕКОМЕНДАЦИИ ПО БЕЗОПАСНОМУ ИСПОЛЬЗОВАНИЮ

- Не размещать VulnNotes в публичной сети и не использовать реальные персональные данные.
- Держать стенд только в изолированной Docker-сети / локальном хосте; ограничить порт firewall.
- Учётные записи демо (admin/admin и т.п.) менять при любом внешнем доступе.
- После практики выполнять docker compose down -v; не оставлять контейнер с SUID-векторами.
- Для «боевой» версии применять меры раздела 5 и проводить повторную оценку по методике раздела 3.
- Разделять роли разработчика и администратора стенда; не выполнять приложение от root на хосте.

7 ВЫВОД

Семантическая составляющая. Разработана многоуровневая методика оценки защищённости (ОС, компоненты, сеть, данные, динамика, организация) и применена к системе VulnNotes. Подтверждены критические нарушения аутентификации, авторизации, криптографии и целостности

обработки данных.

Прагматическая составляющая. Сформированы конкретные меры устранения дефектов и правила безопасной эксплуатации учебного стенда. Методика может повторно применяться к другим сторонним системам (сканеры + ручной анализ по чек-листу).

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Ховард, М. Защищённый код / М. Ховард, Д. Лебланк. – М. : Русская редакция, 2004. – 704 с.
2. Ховард, М. 24 смертных греха компьютерной безопасности / М. Ховард, Д. Лебланк, Дж. Вьегга. – СПб. : Питер, 2010. – 400 с.
3. OWASP Top 10:2025 [Электронный ресурс]. – Режим доступа: <https://owasp.org/Top10/2025/>.
4. CWE – Common Weakness Enumeration [Электронный ресурс]. – Режим доступа: <https://cwe.mitre.org/>.
5. OWASP Vulnerability Scanning Tools [Электронный ресурс]. – Режим доступа: https://owasp.org/www-community/Vulnerability_Scanning_Tools.